SoK: Agent Communication Side Channels Feedback Paths and Executed Cover

***Abstract*—LLM Agents now route user tasks through tool servers, model APIs and other Agents over encrypted channels, and an emerging literature shows that the resulting traffic reveals queries, task types and Agent identities. Defenses are starting to appear, but they are evaluated with methods inherited from website fingerprinting, which assume that cover traffic is free of side effects and that one link is the unit of protection. We systematize fifteen Agent studies (forty-four settings) against twenty-two classical traffic-analysis anchors and find that both assumptions fail in Agent execution. First, tool feedback re-enters model requests, so the same task is exposed on several independently controlled links: a defense that protects one link must be judged against every view its attacker retains. Second, Agent cover is often *executed* as application work, so a privacy result is incomplete without the original task's outcome under the same intervention. The literature has not yet closed this gap. None of the four mapped query/workflow privacy settings reports both an adapted attacker and matched task utility, and the published research-decoy result pairs its privacy gain with utility measured under a different intervention. A paired MCP experiment with two LLM planners shows why the omission matters. Four cover semantics leave recognition at 61–62/120 for one planner and 72–82/120 for the other, yet differ by up to 108 and 68 of 120 fixtures in business-state integrity. Because responses are padded, this observer cannot see how deeply cover executes. Residual recognition instead tracks the trace segments that the cover schedule leaves unprotected. We contribute an access-aware attack and defense map, a classical-to-Agent transfer matrix, a four-step evaluation procedure and a source-dependency analysis showing which conclusions survive without preprints.**

1. Introduction

An Agent receives the instruction *process the next support ticket*. It reads the ticket, checks an order and approval, consults a model, and submits a refund. Encryption hides message contents from a network observer, but the contacted services, traffic sizes and timing remain visible. The tool's answer then becomes part of a model request, which creates a second observable representation of the same task. Suppose a defender adds cover traffic. A second question follows: does that cover end at a proxy, execute a read, or change business state? Figure 1 follows information and actions through this example.

Why systematize now. Agent deployments are converging on a small set of protocols, notably the Model Context Protocol (MCP) over HTTP/2 or HTTP/3, and streamed model APIs [23], [24]. In under three years, studies have recovered research queries from contacted domains [2], recognized tasks from model traffic [9], [4], fingerprinted hosted Agents [1] and attributed models from tool-call behavior [47], [48]. The first defenses are research decoys, relays and shaping [2], [3]. Most of this work is preprint-stage, and no shared evaluation standard exists. Website fingerprinting (WF) went through the same phase, and many early attack and defense results were later reassessed under realistic populations and adapted attackers [32], [15], [16]. An SoK at this point can set evaluation expectations before results pile up that cannot be compared. Its corpus is necessarily small, so we make every conclusion's source dependence explicit.

The question. Which established traffic-analysis evaluation conditions carry over to Agent execution, and which ones break? We find that two assumptions underlying WF-style defense evaluation do not hold, and each produces a concrete evaluation failure.

Finding 1: the unit of protection is a set of links, not one trace. WRA recovers research queries from tool destinations, while ANT and a cloud benchmark recognize task labels on model connections [2], [9], [4]. A contacted tool additionally reads its arguments, and PrivacyTrace shows that these arguments raise attribute inference well above a schema prior [35]. Because tool results are forwarded into later model requests, a tool-side defense leaves the model link outside its scope. In our forwarding pilot, removing supplementary records at the first feedback step still leaves complete-execution model-view recognition at 44/120 for Qwen and 33/120 for Llama, where chance is 20/120 (Section 7.2). A defense claim must therefore name every view its attacker retains (Section 5.1).

Finding 2: executed cover makes utility part of the privacy result. Classical cover terminates at a tunnel endpoint [34]. An Agent decoy can execute queries or update state. The published research-decoy result lowers query recovery from .770 to .565, but its utility scores belong to a separate destination-visibility intervention [2]. Across the four mapped query/workflow privacy settings, adapted attacks appear in two and matched task utility in one, and no setting reports both (Section 8). The field therefore has no privacy–utility operating point for any Agent defense.

Finding 3: in a controlled test, cover semantics change state but not privacy. We test six cover poli-

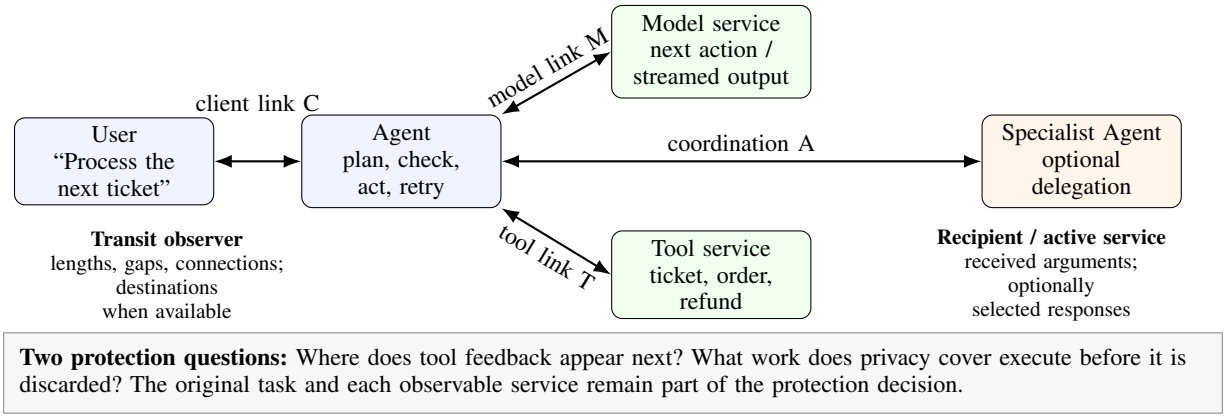


Figure 1. Running support-ticket example and observation rights. A tool result returns to the Agent and can enter the next model request. Each encrypted link exposes its own traffic shape; a recipient additionally sees the request addressed to it. Concurrent tickets may share a connection on either link. The arrows represent application communication, not a one-to-one mapping from tool events to packets.

cies on 1,440 paired held-out LLM-planned executions over MCP Streamable HTTP (Section 7.1). Proxy-discarded, read, isolated and live-write cover leave the validation-selected attacker at 61–62/120 for Qwen3:8B and 72–82/120 for Llama3.1:8B (no cover: 118 and 113). State integrity, however, ranges from 116/120 to 7/120 and from 71/120 to 3/120. For Qwen, a simple last-destination rule (77/120) beats the learned attacker because the frozen schedule leaves the end of the trace uncovered. Under padding this observer is blind to execution depth by design, so the finding concerns what the defender pays, not what the attacker sees. The resulting design rule is to terminate cover as early as the observer model allows, and to spend the budget on schedule coverage rather than on execution depth. The live-write arm is a deliberately adverse control; it measures what a completion-only metric misses, not how often deployed cover causes harm.

Contributions.

- **An access-aware evidence map** of 44 settings from 15 Agent studies. It separates transit, recipient and active observers and binds each score to its target, population and supplied boundaries (Sections 2–3, Tables 1–4).
- **A classical-to-Agent transfer matrix** that labels each established WF and traffic-analysis condition as retained, extended, untested or mismatched in access (Section 4).
- **Two execution-aware syntheses**, of feedback exposure and of cover termination, with a design space of six defense layers (Sections 5–6).
- **Controlled measurements**: the executed-cover study and a forwarding/concurrency pilot. They supply Finding 3 and calibrate how future Agent defenses should be measured (Section 7).
- **A four-step evaluation procedure, an eight-field checklist and a source-withdrawal analysis** that shows which conclusions survive with only published sources (Sections 8–9).

2. Scope and Evidence Construction

The evidence map connects Agent execution to an observed communication signal, a hidden target and the rights needed to observe it.

2.1. Inclusion and retrieval

An Agent uses an LLM to select actions, with external feedback able to affect later action or termination. Client, tool, model and inter-agent interfaces are eligible. Transit observers obtain traffic metadata; contacted recipients see their addressed requests; active auditors also choose probes or challenges. Negative results qualify: PrivacyTrace's metadata/order condition remains included despite scoring below its prior reference [35]. Whole semantic trajectories or browser instrumentation alone enter the adjacent layer, while deliberate covert messages and prompt-injection defenses without communication-side inference remain contextual related work [36], [26].

The fixed eligibility window covers first public submissions from 1 January 2024 through 9 November 2026. Twelve topic queries, a native arXiv query and inclusion rules preceded the retrieval pass; title/publication checks and one-step citation follow-ups completed it. The arXiv query returned 180 records. Public-web queries supplied 33 scholarly candidates across 101 displayed URLs; deduplication yielded 209 records. Two citation leads brought screening to 211: fourteen direct, forty adjacent, 155 outside scope and two unresolved identities. The eligible CHeaT (Cloak, Honey, Trap) seed adds the fifteenth direct source (Figure 2). The SSH honeypot entered through citation tracing, illustrating the value of combining retrieval routes. Exact queries and dispositions are in the supplement.

Twenty-two separately selected mechanism anchors comprise sixteen published communication studies and six serving studies. They supply the established relations in the transfer matrix; the fifteen direct studies supply the Agent application evidence. These layers retain separate inclusion

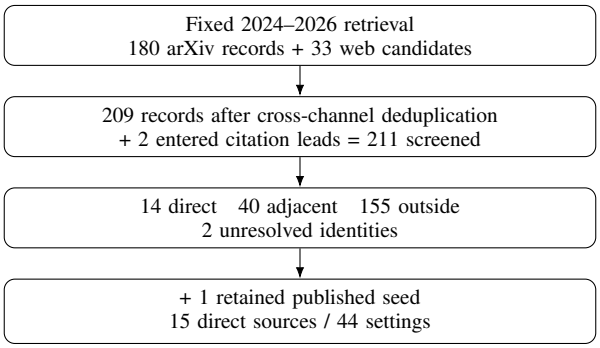


Figure 2. Executed coverage audit. Counts are deduplicated work/lead records; two identities remain unresolved. Mechanism anchors use a separate inclusion rule.

records and denominators. The anchor set is selected for mechanism correspondence, rather than a census of classical traffic analysis.

2.2. Extraction and source dependencies

Forty-four setting records bind source version and locator to access, features, learner, target, population, split, intervention, result and cost. Labels, execution outcomes, failure treatment and policy context are recorded alongside them. WRA and CHeaT are checked against official USENIX texts. One HTTP study has a verified ACM workshop identity, while its detailed measurements come from the extended arXiv version [49], [50]. Twelve other works lack independently verified formal publication identities at the cutoff.

Text reading, displayed-number reconstruction, selected-code inspection and data recomputation have separate entries in the extraction sheet. For example, WRA's decoy and visibility conditions are checked in the published text; OHTTP refitting is checked in selected code. Each check supports its matched premise. Section 9.1 reports what remains when sources are removed. Extraction is author-performed with AI assistance. A coding-manual pilot compares the released author coding with two non-blind AI passes from the same model. Structural fields agree on all forty-four rows, while execution-outcome definitions produce substantial disagreement. Supplement S4.1 gives the original encodings, descriptive agreement and source adjudication; this is not independent human validation. We therefore restrict what the headline claims depend on. Findings 1–2 use only fields on which all passes agree (access class, protection, named transfer), numbers quoted directly from source passages, and the four privacy-setting decisions. Each of those decisions is listed with its locator in Supplement Table 15, so a reader can check it against the source. The low-agreement execution-outcome field enters only the descriptive coverage summary in Supplement S4.

For the descriptive summary, every setting receives an access class and intervention purpose. Protected-condition adaptation and original-task utility are counted within the four query/workflow privacy settings. Three identity-obfuscation settings and two adversarial-Agent blocking settings have different objectives; thirty-five settings contain no protection comparison. A located item identifies evidence in the retained record. An unlocated item leaves that question open. The supplementary reporting ledger lists the assignments and source locators.

2.3. Relation to security surveys and Agent defenses

Broader surveys organize LLM and Agent threats by lifecycle, attack surface and defensive role [53], [54], [55]. This SoK asks three communication-specific questions: which service representation reaches which observer, whether an intervention covers the later feedback path, and what business work its cover can trigger. The maps connect each answer to a measured setting and its evidence strength. The supplementary deployment section compares these surveys and WF systematizations.

Information-flow and privilege controls address closely related execution boundaries. CaMeL tracks dependencies and explicitly discusses tool-call and timing side channels [57]; FIDES enforces confidentiality/integrity policies and selectively exposes tool information [58]; Progent constrains tool calls and arguments [59]. SPILLage distinguishes content and behavioral oversharing by browser Agents [27]. Our maps add the communication-observer question: which metadata remain visible under a particular deployment and intervention? They do not replace these policy mechanisms. Likewise, τ-bench and AgentDojo already evaluate environment outcomes [60], [61]. The cover example applies state-aware evaluation to matched traffic measurements; state checking itself is established practice.

3. Reading the Evidence Map

The same ticket can expose different facts at the network link, the tool recipient and the model service.

3.1. From private task to observed execution

An execution maps a hidden task or state through an agent policy and environment into communication, then into an observer's features:

$$\text{hidden task/state} \longrightarrow \text{agent execution} \longrightarrow \text{observed communication} \longrightarrow \text{inference}.$$

Different cuts through this chain expose different objects. A client link can reveal response mode or hosted-agent identity. Tool egress exposes contacted services and request/response shape. The model link carries prompts, tool feedback and model responses. Inter-agent links expose delegation and coordination. Figure 1 places these observations on the feedback path.

3.2. What the inferred label means

The ticket example separates four labels. *Intent* is the requested objective or assigned task family. *Execution* is the recorded action sequence. *Success* states whether that sequence and its final state meet the task's criterion. *Authorization* states whether the action is permitted for the principal under the applicable policy. A failed refund task can still contain a refund attempt; a successful refund can still be unauthorized. An evaluation should bind its target to the corresponding reference instead of letting one label stand for all four.

Exposure is relative to both the target and the observer. The same execution may expose intended-task information on M and actual contacted services on T. Initial instructions, tool feedback and later decisions all contribute to the complete M trace. Assigning a task-family label to that trace measures intention recognition; attributing the signal to a particular feedback step requires a further controlled comparison.

3.3. What each record specifies

Six fields give a score its meaning: the *interface and visible representation*; *observer access*; *prior information* supplied by the evaluator; *target*; *population and base rate*; and *protected training access*. These fields define the comparison record. The matrix records the fields once; the reporting checklist in Section 8 turns them into entries for future studies.

Access determines what a feature can mean. A server can inspect decrypted HTTP/2 properties that a transit observer cannot. The content-aware MCP study's "metadata" includes argument hashes, and its graph uses content matches [42, Secs. 4.1–4.2]. Its representation therefore requires more than packet metadata. Logs and browser instrumentation can provide evaluation labels without becoming attacker inputs.

ANT's supplied stage boundary is prior information; its 2,101 stages and 47 labels define the decision population; the primitive is the target [9]. In the live OHTTP comparison, an unchanged random-forest (RF) family refits on protected data, so it is an adapted attacker [3].

3.4. Deployment determines who can see each signal

Table 1 maps common deployments to observation rights and the corresponding source evidence. A visible model link is an access condition, not a property granted to every attacker. Captured packets, TLS records, HTTP streams, server-sent events (SSE) and tool calls are different units. Segmentation, buffering and retransmission change their correspondence. Supplement S7 gives the protocol-level map.

Two simultaneous tickets may use separate connections or share an encrypted HTTP/2 connection. In the latter case, a transit observer sees combined packets while stream identifiers remain encrypted. A gateway that buffers SSE output changes the pattern again. The connection and flush policy therefore determine the measured trace.

The same reasoning explains defense placement. Padding a tool message before a gateway does not specify the gateway's output. Local MCP over `stdio` removes that network tool leg, while remote model requests may remain. Shared key/value (KV) cache state creates an additional timing interface for a querying tenant. The map therefore records the transport, observation layer, terminating parties and shared state alongside each result. Section 7.2 compares real HTTP/2 concurrency with paired feedback and shaping interventions.

4. Classical Conditions in Agent Execution

Established traffic-analysis results carry conditions on access, observation units, workloads and interventions. Table 2 connects those conditions to the Agent evidence. Its central distinction is between an evaluation principle that carries over and an empirical performance result that requires a matched Agent test.

4.1. Reading the transfer matrix

Open-world prevalence, false alarms, adaptive attacks and workload shift are established concerns [15], [46], [32], [16], [52], [19]. Localization also has direct precedents: Wang and Goldberg study traffic splitting without reliable page boundaries; BAPM and ARES address mixed multi-tab traces [45], [43], [44]. WF is neither inherently deterministic nor restricted to one link. Here these issues interact with feedback across independently controlled services and cover executed as application work.

Retained means that an established evaluation obligation still applies; *extended* identifies an additional Agent execution condition; *access mismatch* prevents importing a result under the proposed observer; and *untested* means that the mapped evidence leaves the specific performance claim open. These relationships are separate from the number and publication status of supporting sources. Distributed tracing illustrates access mismatch: WAP5 and vPath use host instrumentation [30], [31], which can label an experiment without becoming a passive attacker's input.

Five questions locate the resulting evidence: signal mechanism, supplied-unit recognition, named deployment transfer, stream localization and protection. They are distinct tests. A reported score binds a target to an observation and a tested deployment; Tables 3–4 preserve those bindings across the field.

4.2. Task boundaries and execution changes

AgentPrint supplies browser interactions, WRA research traces, the communication-graph study workflows, the cloud benchmark execution timestamps, and ANT runtime-defined stages [1], [2], [3], [4], [9]. ANT's 47-group primitive test

TABLE 1. DEPLOYMENT AND ACCESS MAP. THE CONFIGURATIONS ARE ANALYST-DEFINED; CITED SETTINGS TEST THE LISTED VIEW, NOT EVERY COMPONENT OF THE DEPLOYMENT. A GATEWAY'S PLAINTEXT ACCESS REQUIRES TLS TERMINATION.

Deployment	Observer and permitted view	Existing evidence for that view	Protection consequence
Enterprise egress	A transit monitor sees routed model/tool flows, sizes, times and any exposed destination association.	WRA: supplied research-domain traces; ANT and cloud benchmark: model/combined traffic [2], [9], [4].	Specify which services cross the monitored egress. A union of flows is available only when the monitor can observe them.
Shared gateway or relay	Transit sees multiplexed gateway output. A terminating gateway can additionally read addressed requests.	Live OHTTP: passive-link inference under stated relay trust [3]; PrivacyTrace: semantic recipient/gateway access [35].	Separate relay association protection from content trust. Connection sharing changes the observation unit.
Local model, remote tools	An external observer sees remote tool traffic; the local model call has no corresponding external network leg.	WRA's destination-recovery mechanism is relevant to tool egress [2]; whole-deployment protection is untested in the mapped comparison.	Evaluate tool and downstream calls. Do not import a remote-model attack score into an absent network leg.
Cloud model, remote tools	An authorized vantage may see either or both encrypted legs. A contacted tool sees its own arguments.	ANT/cloud benchmark test model traffic [9], [4]; PrivacyTrace tests recipient-visible representations [35].	Check permitted model and tool views after the intervention; recipients and passive monitors need different protections.

scores 0.355–0.462 accuracy on 2,101 supplied segments. Its episode split separates parent executions, while the supplied boundaries define a recognition test. Event localization additionally requires recall and false events on proposed intervals.

PersonaFingerprint keeps one session's windows in one partition [5]. A neighboring published study classifies non-overlapping 5,000-packet windows without page markers, primarily testing human browsing with Agent-generated training traces [41]. PINGPONG and voice-invocation work demonstrate detection against background traffic [33], [22].

Transfer names what changes while the target remains fixed: wording, session, composition, topology, scaffold or model. Reported composition, topology and scaffold losses concern different axes (Section 5.3). Simultaneous Agent tasks and model waits also change how tool bursts relate to complete executions. Our live comparison separates supplied-window inference from localization and retains physical connection identities.

5. Two Execution Boundaries for Protection

The field map connects two properties of Agent execution to defense design: information passes between services, and cover can become application work. Table 5 states the observation conditions under which particular signals matter.

5.1. Finding 1: feedback joins separately observable services

The support-ticket execution exposes a selected tool destination, arguments received by that tool, a later model request and the model's response. WRA recovers query meaning from contacted domains under its name-association and supplied-trace conditions [2]. ANT, a network-traffic benchmark for Agent behavior, and the cloud benchmark measure task recognition from model traffic [9], [4]. The cloud benchmark reports ten-class balanced accuracy .853/.860 for graph/star coordination with all 247 features, and .540/.587 when size features are excluded and 100 of the 134 remaining features are selected. Both feature availability and selection change in that comparison. ANT's model-view values reconstructed from rounded figures remain approximate quantities in Supplement S2.

Recipient access changes the inference problem. PrivacyTrace's tool metadata/order yields attribute-inference ASR 14.53%, below its 17.97% schema-prior reference; adding arguments yields 27.71% [35]. MARK's combined F1 .971 also uses browser behavior, while its protocol/header features are available at the contacted website [6]. Encryption against transit observation does not hide an addressed request from its recipient.

These results identify where task information is observable. They lead to a testable question: with the initial instruction fixed and task-bearing feedback released later, how much recognition remains on the model link under a stated tool-side policy? Section 7 tests this question with constructed schemas and reports both the first-feedback and complete-execution views. Initial instructions, retained task fields and model responses are distinct possible contributors to the latter.

Defense consequence. Enumerate the services and representations available to the attacker, then evaluate the views remaining after an intervention. A joint observer can use a single-link decision rule, even when a particular fitted joint classifier scores lower. At the application boundary, minimize forwarded context while preserving the information needed for the task; at the transport boundary, evaluate visible sizes, timing and association. Their effects belong to

TABLE 2. TRANSFER OF ESTABLISHED CONDITIONS TO AGENT EXECUTION. RELATIONSHIP LABELS CONCERN THE STATED MAPPING; EVIDENCE STRENGTH AND MISSING TESTS APPEAR SEPARATELY. A MISSING AGENT TEST DOES NOT REFUTE THE CLASSICAL RESULT.

Established relation and condition	Agent mapping / consequence	Relation	Agent evidence and remaining test
Unknown boundaries and background affect event recognition [45], [43], [44], [33].	Tool bursts, model waits and task intervals are different units. Evaluate proposed events with false alarms as well as classification.	Retained	ANT supplies stage boundaries; the local concurrent study tests particular detectors. Greater Agent localization difficulty is untested.
Defense evaluation must allow adaptation to the protected distribution [32], [16], [19].	Record protected training access and still-visible links; an unchanged learner family can refit.	Retained	Transformed and live OHTTP settings report adaptation in one preprint [3]; WRA's matched protected examples remain unresolved.
Coarse timing/volume can remain useful under specified padding [32]; serving streams expose length/gap signals [20], [12].	Name the shaping policy, receiving hop and Agent workload before carrying over a measured effect.	Untested generalization	Cloud and ANT measure model-view recognition [4], [9]. A general protected-Agent SSE claim is not tested by these observations.
An observation result is tied to the visible paths and representations [28], [34].	Feedback forwards tool information into later model requests across separately controlled services; evaluate every permitted residual view.	Extended	Published WRA tool-side evidence and preprint model/recipient results establish different exposed interfaces. Causal feedback attribution needs its own test.
STP tunnel endpoints remove cover before it reaches devices or servers [34, Sec. 7.1].	When cover executes as research, add original-task resource, state and feedback constraints to the traffic budget.	Extended	Published WRA reports executed research decoys and utility under a different intervention [2]. Our controlled LLM case separates task completion from state integrity (Section 7.1); it does not evaluate WRA writes.
Host traces can reconstruct distributed request paths [30], [31].	Instrumentation can provide ground truth; a transit attacker must infer from its own permitted observations.	Access mismatch	ANT stage labels and local task intervals are evaluator-provided. Host tracing alone cannot establish passive encrypted-stream localization.

separate contrasts.

5.2. Finding 2: cover termination determines the execution constraint

Transport cover can terminate before business execution. Executed cover performs work and may affect resources, state or later decisions. The difference determines which utility must accompany a privacy measurement.

WRA's five research decoys reduce functional query recovery from .770 to .565 [2, Sec. 8.1]. Its utility scores 8.55 and 8.54 instead compare 100% and 10% destination visibility. Thus the utility observation does not describe the decoy intervention that produced the recovery reduction. WRA establishes additional research execution; it does not report harmful business-state writes. Matched protected-condition attacker examples also remain unresolved in the selected evidence.

The live OHTTP study refits a random forest on each protected capture and pairs six-class accuracy .30 with approximately thirteen-fold bytes and eleven-fold latency [3, Sec. 9.7]. Its separate nine-class .67 score belongs to another comparison. This design point binds adapted inference to transport cost; matched original-task utility was not located.

Task completion is only one execution outcome. The requested refund can satisfy its target postcondition while another order, shared quota or ledger entry violates the application's state contract. Cover placement therefore determines what must be checked alongside completion. Section 7.1 illustrates this distinction with paired LLM executions and reports inference, state and resource outcomes together.

Defense consequence. An executed-cover design needs a semantic constraint alongside a traffic budget. It can terminate decoys before business execution, or isolate their resources, state and planner feedback. These are testable design choices: measure adapted inference, additional work, original-task completion and collateral state changes on the same protected runs. The published WRA text supports the intervention/utility distinction; the OHTTP refit/cost example depends on one preprint.

5.3. Execution changes delimit the two findings

A private recurring routine can be recognizable while its classifier transfers poorly to a new execution organization. In the communication-graph study, composition holdout keeps the nine workflow labels but changes their capability combinations: accuracy changes from about .67 to .18, with zero recall for seven classes [3, Sec. 9.12]. The cloud benchmark's graph/star change separately reports about .83

TABLE 3. ATTACK FIELD MAP, PANEL A: TRANSIT OBSERVATIONS. SCORES RETAIN THEIR METRIC, TASK AND SUPPLIED UNIT; THEY ARE REPRESENTATIVE REPORTED OPERATING POINTS, NOT A CROSS-PAPER RANKING. THE MATRIX RECORDS ALL FORTY-FOUR SETTINGS. P: INSPECTED PREPRINT; V: INSPECTED PUBLISHER VERSION.

Interface / observer	Work / target	Observable features / learner	Evaluation unit	Reported result and boundary
Client–agent; transit	AgentPrint [P] [1]; hosted agent	Directional packet counts/bytes in 1,800 relative-time bins; CNN	Supplied browser interaction	Mixed-flow macro-F1: .8660 closed, .8477 open; 50 monitored agents. Behavior-F1 conflict is kept separate.
Agent–Web; transit	WRA [V] [2]; research query	Contacted domains and timing; ICL or fine-tuned LLM	Supplied research trace	Functional query recovery .770 with domains; .725 with domains plus timing in the compared visibility views. This is a reconstruction score.
Inter-agent / tools; transit	Communication graphs [P] [3]; workflow	Message/graph, size and timing descriptors; random forest	Workflow record	Nine-class accuracy .67; within-label composition holdout .18. The live defense test instead has six classes.
Agent–model; transit	Cloud benchmark [P] [4]; assigned task	247 traffic descriptors; random forest	Logged successful run	Ten-class balanced accuracy .853/.860 for graph/star coordination. Size-excluded feature protocols score .540/.587.
Agent–Web; transit	PersonaFingerprint [P] [5]; browsing persona	Signed lengths/interarrival times; CNN representation and prediction heads	Fixed packet window; session split	Per-site macro-F1 about .78–.91; pooled-summary discrepancy excluded from synthesis. Explicit other-class tests have a different population.
Combined egress, M or remaining links; transit	ANT [P] [9]; task, primitive, risk	Direction/length/time; 13 learners including DF and TikTok	Supplied episode or logged stage	Five-task accuracy .431–.727; 47-primitive accuracy .355–.462. Risk test: 20 positive/189 negative, requiring recall and false alarms.

to .52 under its corresponding feature protocol [4]. Each axis depends on one preprint.

Implementation and failure handling can also change the observation. Trace reports macro-F1 .981 in its mixed-session model-attribution test and .815 on scaffold hold-out, retaining 1,010 of 1,050 planned clean runs [48]. AgentTrace's active probes reach 66.8% attribution from initial outcomes and 96.0% from ordered repairs at fifty probes [47]. Excluding failed sessions and observing recoverable errors are different operations. These source-specific conditions delimit what an attack or defense says about new workloads; they do not estimate a common filtering effect.

Finally, a traffic target retains its own security meaning. ANT labels benchmark risk, AgentTell tests action choice under a disclosure rule, and CHeaT measures prevention of a defined CTF objective [9], [8], [10]. Authorization additionally requires a principal and policy context. Two refunds that differ only in an unobserved approval can have identical traffic. This conditional argument identifies the extra policy input an authorization monitor needs.

6. Defense Mechanisms and Execution Costs

Defense placement determines both the signal changed and the party that must enforce the change.

6.1. What a defense changes

Table 6 organizes six intervention choices by enforcement point, trust, cost and residual signal. Association defenses hide a destination or its link to a user. Padding changes sizes, while scheduling changes temporal structure. Transport cover can terminate before business execution; execution cover adds real work. State isolation limits shared-resource signals, and content minimization limits what a recipient learns. These choices can be combined, but their costs and remaining views must be evaluated together.

6.2. Relating communication defenses to Agent execution

STP illustrates transport cover that can terminate at a tunnel endpoint [34]; Walkie-Talkie and FRONT provide shaping mechanisms [17], [18]. For the ticket Agent, this could mean padding the tool response at an egress proxy, pacing model tokens, or sending cover to a trusted terminator. Calling the refund tool as a decoy would instead cross the business-state boundary. The intervention must therefore specify both where cover is removed and what work it can trigger. Constant-rate shaping in the style of BuFLO and Tamaraw [32], [62] fits Agent traffic poorly. Model waits create long idle periods that the defense must fill, and streamed responses can exceed any fixed schedule. In our pilot, joint model-link shaping cost 19.5–22.5$\times$ bytes, and 1,818 of 2,736 shaped responses overran the minimum schedule, with no detectable additional reduction in recognition or localization (Section 7.2).

The measured design points occupy different parts of this space. WRA changes executed research, live OHTTP changes destination association, and the paired forwarding study changes the context sent to the model. Section 5

TABLE 4. ATTACK FIELD MAP, PANEL B: CONTACTED RECIPIENTS AND ACTIVE AUDITORS. THESE OBSERVERS SEE REQUESTS ADDRESSED TO THEM OR ISSUE PROBES; THEIR RESULTS DO NOT MEASURE ENCRYPTED-TRANSIT INFERENCE. E: INSPECTED EXTENDED PREPRINT WITH A SEPARATELY VERIFIED PUBLISHED SHORT VERSION. NR: NO RECOGNITION RATE REPORTED IN THE MAPPED SETTING. ASR: ATTACK SUCCESS RATE.

Interface / access	Work / target	Observable features / learner	Reported result and evaluation boundary
Web recipient	MARK [P] [6]; client identity	TLS/HTTP2 and headers; decision tree	F1 .725 for TLS/HTTP2, .799 for headers; .971 combined with browser instrumentation, a richer view. First-pass trials.
Web recipient	Fayolle et al. [P] [7]; client / access	Protocol signatures; richer behavior classifier and site challenges	Fingerprint analysis excludes failed visits. Access success is separately verified through form/cookie/page identifiers; not a privacy score.
Documentation recipient	HTTP signatures [E] [49]; service/client	Request method/version, headers and origin; descriptive comparison	Nine coding agents and six assistants, three trials each; NR. Request signatures are observations, not a held-out identification rate.
Terminal recipient	Trace [P] [48]; model family	Command TF-IDF unigrams/bigrams; linear SVM	Seven families; 2,028 clean/injected sessions: macro-F1 .981; held-out scaffold .815. A separate proprietary-scaffold test reports 78% accuracy.
Tool interface; active audit	AgentTrace [P] [47]; model identity	Serialized arguments, parser errors and repair order; Markov likelihood	Six models, 50 held-out probes per trial: 96.0% accuracy; 10 probes: 92.8%. Repeated stochastic trials reuse probe identities.
Web recipient; active choice	AgentTell [P] [8]; prior-origin fact	Which offered action is requested; loaded/cold comparison	Matching choice in 61.1% of 7,630 loaded sessions; the leakage measure subtracts cold matching. Actions share a completable probe task.
Tool recipient / gateway	PrivacyTrace [P] [35]; profile attribute	Tool metadata/order; content-added LLM inference	Metadata ASR 14.53%, schema prior 17.97%; arguments 27.71%. 68,000 attribute slots are clustered within 4,000 trajectories.
Contacted asset; active challenge	CHeaT [V] [10]; agent presence	Planted URL following; separate password-output control	Presence-detection mechanisms, NR for natural-traffic classification. Capture-the-flag prevention is a distinct endpoint (Supplement S7).
SSH recipient; active probes	LLM Agent Honeypot [P] [51]; possible agent	Prompt compliance and response-time heuristic	Three-month deployment: eight candidate agents among 8,130,731 interactions. No externally verified field labels or detection precision/recall.

gives the source-specific recovery and cost results; Section 7 tests cover execution, forwarding and connection policies. Supplement S7 retains the complete defense map, including identity obfuscation and adversarial-Agent blocking as distinct objectives.

6.3. Choosing a layer in practice

Start from the private object and the observer's rights. Protect destination associations when contacted domains expose the query; protect visible model output sizes and timing when those carry the target; minimize sensitive arguments when the recipient is the observer. Then test what remains on other permitted links. A shared gateway changes which tasks contribute to a connection, so its connection policy belongs in the evaluation. For executed cover, bind privacy, token/tool use, requested-task completion and whole-state correctness to the same protected runs. Where the observer sees only padded metadata, terminate cover at a proxy and spend the budget on schedule coverage; execution depth added no measured privacy (Section 7.1). These choices turn the risk map into a deployment-specific protection plan.

7. Controlled Measurements at the Two Boundaries

The source map shows what the literature has not measured. Here we measure two of those gaps directly. The cover study binds recognition, target-task completion, whole-state integrity and cost to the same executions; it supplies Finding 3. The forwarding pilot tests the feedback path and calibrates how such tests should be run. The two studies keep separate populations and inferential results.

7.1. Joint traffic and execution measurements

The study compares six cover policies on matched synthetic support tickets. Two fixed-weight models, Qwen3:8B and Llama3.1:8B, each run 300 fixtures per condition: 120 training, 60 validation and 120 test, balanced across six actions. The 3,600 episodes have terminal results. Fixtures and cover draws are paired across conditions; request phrasings recur across splits.

Execution and observation. The models choose checks, business actions, objects, recovery and termination through LangGraph [56]. A controller fetches the ticket and enforces prerequisites without supplying the cor-

TABLE 5. CONDITIONAL RISK MAP. A ROW APPLIES WHEN ITS ACCESS AND EXECUTION CONDITIONS HOLD. THE FINAL COLUMN STATES A PROTECTION PRIORITY OR DESIGN HYPOTHESIS, NOT A DEMONSTRATED MITIGATION. SCORES, TARGETS AND RIGHTS DIFFER ACROSS ROWS, SO THERE IS NO GLOBAL DANGER RANKING.

Interface and signal	Condition and evidenced inference	Protection consequence
Tool egress: selected domains and timing	The observer can associate contacted names with a supplied research trace. WRA recovers query meaning; linked histories use a separate persona endpoint [2].	Prioritize destination association when the private target is research intent. Reduced name visibility needs a residual traffic assessment; executed decoys need task-utility constraints.
Model link: lengths, directions and timing	Model traffic is visible and associated with the evaluated task. ANT and the cloud benchmark measure task information in this view [9], [4]. Initial instructions and later feedback coexist.	Tool-only protection leaves this view to be assessed. Compare model-only and joint adaptive attacks; isolate feedback before choosing a feedback-specific defense.
Coordination: message graph, volume and sequence	Workflow records or coordination traffic expose execution organization. Composition and topology transfer tests change that organization under known task labels [3], [4].	Target observable scheduling and association, not just one payload size. Evaluate changed compositions and topology separately from recurrent-workflow privacy.
Client link: packet counts, directions and bursts	AgentPrint's supplied browser interactions support hosted-agent identity inference [1]. The result presumes those observation units and identities.	Client-facing traffic needs its own protection assessment even if tool links are hidden. Task discovery and new identities require separate tests.
Contacted recipient: headers, commands or arguments	MARK, Trace and PrivacyTrace use recipient-visible representations. In PrivacyTrace, metadata alone is below its prior, while adding arguments improves attribute inference [6], [48], [35].	Minimize sensitive request content and assess implementation signatures. Transport encryption does not conceal the recipient's intended plaintext.
Active probing: challenges, choices and repairs	A party can elicit responses and observe later behavior. AgentTrace attributes models from repairs; AgentTell observes a choice under a disclosure rule [47], [8].	Test error normalization and restrictions on cross-context disclosures while retaining task recovery. These hypotheses need active-access evaluations.

rect action. Seven local MCP Streamable HTTP destinations use TLS 1.3/HTTP/2, a common `/mcp` path and request/response padding quanta of 4,096/16,384 bytes. The observer receives destinations and bidirectional ciphertext byte counts within supplied episode and call windows. Timing and model traffic are outside this view.

A frozen schedule inserts one or two random decoys among early tool calls. The conditions are no cover, proxy discard, read cover, isolated execution, live write, and isolated execution with visible responses. Proxy discard computes on a disposable copy; isolated execution retains a separate clone. Live writes deliberately modify the primary fixture, including other orders or shared quota. The visible control sends clearly marked cover responses from the clone to the planner. Other cover responses are hidden. The live-write arm is an adverse control selected to exercise collateral changes. Proxy discard also computes a disposable response; it is not a pure transport-only dummy.

Matched endpoints and attacks. *Goal completion* checks the requested action/object, prerequisites and target postcondition. *State integrity* checks the entire business state against the single intended-action reference. We also count completed tasks with state errors directly; the two predicates are not nested. Recognition predicts the requested action including failed executions. Logistic regression (LR) and random forest (RF) train within each condition, with validation selecting the primary attacker. Frozen and destination-position attacks are retained alongside them.

Each endpoint has a prespecified twelve-test Holm family: five cover-minus-baseline contrasts and visible-minus-hidden for each model. Conditional intervals resample paired fixtures by action, holding fitted attacks fixed. Supplement S8 contains every attack and contrast, state replay and a worked evaluation protocol.

Recognition follows the schedule, not the cover semantics. Every cover policy reduces requested-action recognition, and all ten primary cover-versus-baseline contrasts survive correction. The four hidden-response policies differ only in what the decoy executes. For Qwen they leave the selected attacker at 62, 62, 61 and 62 of 120 (proxy discard, read, isolated, live write); for Llama the range is 72–82. Executing deeper therefore gave no visible privacy benefit to this observer. This is largely what the padding predicts. Responses are padded to 16,384-byte quanta and timing is outside the view, so read, write and discarded decoys should produce near-identical shapes. The result's value is in quantifying the other side: under one fixed observer, the choice of semantics changes only the state damage. The comparisons are against no cover, the policies are not tested pairwise, and Llama's 10-point spread shows that we do not

TABLE 6. DEFENSE DESIGN SPACE: ENFORCEMENT AUTHORITY, COSTS TO MEASURE AND REMAINING EXPOSURE. SOURCE-SPECIFIC MEASUREMENTS APPEAR IN THE TEXT AND SUPPLEMENT S7.

Layer / mechanism	What must be trusted or controlled	Costs to measure together	Residual exposure and practical decision
Naming / association: encrypted name resolution, relays, OHTTP	Name resolver or relay placement; the parties able to link the user to the destination	Added hops, bytes, latency and availability	Shape can survive name hiding. Choose this layer when destination association is the private target; then test remaining observers.
Representation: message, TLS-record or packet padding	Component that controls the final visible size; padding survives later encoding	Added bytes, record/packet count, fragmentation	Timing, count and other links remain. State the padding layer and test downstream captures.
Scheduling: batching, pacing, fixed-rate cover	Sender/relay controls output schedule and cover lifetime	First-response delay, completion delay, bandwidth during idle periods	Admission, termination and overflow can reveal activity. Budget these events as part of the visible trace.
Transport cover: dummy exchanges discarded at a tunnel endpoint	Trusted cover terminator; no dispatch into business tools	Cover bandwidth, queueing, resource use	Other endpoints still see their inputs. Prefer this boundary when the aim is traffic shaping without extra business work.
Execution cover: extra research or tool calls	Tool privileges, isolated state and whether decoy feedback reaches the planner	Model tokens, tool quota, task success, state changes and latency	A decoy can affect the real execution. Measure privacy and original-task utility on the same protected runs.
Shared-state isolation / minimization	Tenant separation, cache keys and information passed between services	Lost cache reuse, compute, latency, task accuracy	Isolation removes a sharing channel, not every traffic signal. Minimize tool arguments and feedback according to each recipient's role.

TABLE 7. EXECUTED COVER: ALL HELD-OUT CONDITIONS, 120 PAIRED FIXTURES PER MODEL AND CONDITION. RECOGNITION COLUMNS COUNT CORRECT REQUESTED-ACTION PREDICTIONS; CHANCE IS 20/120. THE LEARNER IS SELECTED USING VALIDATION LR/RF ACCURACY. THE POSITION RULE REMAINS VISIBLE WHEN IT IS STRONGER. GOAL, WHOLE-STATE INTEGRITY AND COMPLETED TASKS WITH STATE ERRORS ARE SEPARATE ENDPOINTS.

Model	Cover policy	Selected	Last dest.	Goal	State	Goal + error	Call bytes ×
Qwen3:8B	No cover	118	116	114	116	0	1.00
Qwen3:8B	Proxy discard	62	77	114	116	0	1.34
Qwen3:8B	Read cover	62	77	114	115	0	1.34
Qwen3:8B	Isolated, hidden	61	77	114	115	0	1.34
Qwen3:8B	Live write	62	75	102	7	95	1.34
Qwen3:8B	Isolated, visible	63	77	113	114	1	1.35
Llama3.1:8B	No cover	113	79	82	69	13	1.00
Llama3.1:8B	Proxy discard	79	67	80	68	13	1.29
Llama3.1:8B	Read cover	72	67	84	71	14	1.28
Llama3.1:8B	Isolated, hidden	82	67	83	70	13	1.28
Llama3.1:8B	Live write	80	65	76	3	73	1.29
Llama3.1:8B	Isolated, visible	81	68	83	73	11	1.29

claim equivalence. What does limit protection is coverage. The last-destination rule reaches 77/120 for Qwen under every hidden policy, above the selected learner, because the frozen schedule places decoys only among early calls. For Llama the learner remains stronger (72–82 vs. 65–67). Extending coverage to the end of the trace is therefore the indicated next defense. It is an inference, not yet a measurement, and a timing-capable observer could make execution depth matter (Section 9).

State integrity follows the cover semantics. The same policies differ sharply in what they do to the application. Proxy discard, read and isolated cover keep Qwen's whole-state integrity at 115–116/120, close to no cover. Live writes reduce it to 7/120, and for Llama from 69/120 to 3/120. Both reductions survive correction. Completion falls by only 10.0 and 5.0 points, and only Qwen's drop is significant. Among completed tasks, 95 of 102 (Qwen) and 73 of 76 (Llama) carry collateral state errors, against 0 of 114 and 13 of 82 without cover. A completion-only utility metric would therefore have scored the most damaging policy as nearly harmless. We chose live writes as an adverse control in order to exercise this gap. The counts show what completion misses; they do not estimate how often deployed cover causes harm.

Design consequence and cost. Together, the two contrasts favor the cheapest boundary that the observer model permits. For Qwen, proxy discard matches isolated execution in recognition (62 vs. 61), completion (114/120) and call bytes (1.34×), and it retains no decoy state. Isolation or execution is justified only when the observer can see something that requires realistic downstream work, such as response timing or third-party calls. That case lies outside this tested view.

Making isolated cover responses visible to the planner raises mean prompt tokens by 18.1% and 18.9%. All primary visible-minus-hidden contrasts have adjusted $p = 1$. Planner paths vary between paired runs, and we have no repeated-condition cohort, so this average effect remains unresolved (Supplement S8).

7.2. Forwarding and concurrency pilot: three measurement lessons

A separate pilot holds initial messages fixed and varies whether supplementary tool records enter the next model request. *Full* forwards the whole response; *Projected* keeps only task-required fields. The synthetic records deliberately carry action information. Two fixed 8B models perform 3,120 local LangGraph/MCP executions over streaming TLS 1.3/HTTP/2. Each test condition has 120 tasks in twenty nonempty and four empty sessions. Supplement S1 reports every attack, phase, interval and outcome. The pilot is underpowered for its declared 10-point effect, so we report it for the evaluation lessons it supports and not as a causal result.

Lesson 1: single-step minimization does not contain the task. First-feedback LR recognition falls from 43 to 23 correct for Qwen and from 40 to 22 for Llama. None of the eight primary local comparisons rejects after Holm correction (minimum adjusted $p = .0508$). Over the complete execution, the projected model view still reaches 44/120 and 33/120, against chance at 20/120. Later requests and responses carry task information that a first-step filter does not remove, which is Finding 1 measured on one deployment.

Lesson 2: evaluate shaping with a view that still works. In the concurrent conditions, each supplied window mixes the traffic of all tasks active at the same time. Recognition over both links is therefore already near chance with dedicated connections (30/120 and 20/120). Connection sharing (23 and 19) and joint shaping (20 and 22) cannot improve on a view that is already uninformative, so this view says nothing about shaping itself. Event localization remains informative and gives the fair test. Learned-detector F1 at IoU .5 is .117–.274 with joint shaping versus .077–.249 without, at 19.5–22.5× model-link bytes. Shaping evaluations should therefore use an attacker view that still works under the workload's concurrency. This echoes the classical observation that costly padding can buy little against coarse features [32].

Lesson 3: event metrics are sensitive to the matching rule. Continuous detectors receive connection identities but no task windows. Their shared-condition precision is 4.3–18.6%, with 8.21–44.79 false events per test session at IoU .5. A constant all-active baseline outranks the learned detectors at IoU .3 and falls below them at .5. Agent localization claims should therefore report several overlap thresholds and a constant-output reference.

8. Evaluating Both Boundaries

An intervention needs one record linking the attacker's remaining observations to the original task and allowed collateral effects. Table 8 shows why this joint record matters: among four query/workflow privacy settings from two sources, adaptation is documented in two and matched original-task utility in one, with no setting documenting both. The adapted settings share a preprint; the utility observation is WRA's published visibility comparison. These are descriptive counts of inspected configurations.

8.1. A minimal evaluation procedure

The following procedure connects established evaluation guidance [52], [15], [16] to the information and action boundaries. It is a proposed reporting procedure, illustrated by the controlled cover case. The six observation-contract fields in Section 3 specify an inference setting; the eight checklist items organize the broader study report, including its outcomes, uncertainty and provenance.

1) **Declare the target and permitted observations.** Name the private fact, visible model/tool/recipient interfaces, access rights and any supplied execution windows. Track where tool results are forwarded.
2) **Declare the allowed execution effects.** Specify the original goal, other objects that may change, resource budgets and what cover may return to the planner. Use business invariants that permit legitimate concurrent updates; exact state equality fits only a correspondingly constrained fixture.
3) **Pair protection, attacks and outcomes.** Evaluate the baseline and intervention on matched tasks. Train permitted attackers on protected executions and include attacks that exploit the cover schedule. Record goal completion, completed tasks violating the state contract, and bytes, delay and resource use on those same runs.
4) **Make the decision against stated tolerances.** Report attack-specific inference and uncertainty together with task, state and resource tolerances fixed before evaluation. A completed task with a state change outside the declared contract fails its utility requirement. Successful inference on another permitted view defeats a claim of containment across those views. An unsuccessful tested attack supplies no general secrecy guarantee.

Worked application. Section 7.1 follows steps 1–3 for a tool-metadata observer. Step 4 is where completion-only reporting would have failed: live writes pass the goal

TABLE 8. EVIDENCE LOCATED IN THE RETAINED RECORDS. COUNTS USE ELIGIBLE SETTINGS; THE SECOND COLUMN ALSO GIVES DISTINCT SOURCES. "NOT LOCATED" LEAVES EVIDENCE UNRESOLVED WITHIN THE INSPECTED SCOPE. THESE COUNTS DESCRIBE AVAILABILITY, NOT STUDY QUALITY OR CHECKLIST VALIDITY.

Question	Eligible settings / sources	Located	Supporting settings and consequence
Protected-condition attack adaptation	4 / 2	2/4	Communication graphs: transformed captures and live OHTTP. Both come from one preprint.
Original-task utility under the same intervention	4 / 2	1/4	WRA visibility comparison. It does not price WRA's executed-decoy condition.
Adaptation and original-task utility in one setting	4 / 2	0/4	Adaptation and utility are located in different records; transport cost alone does not fill the task-outcome field.
Original-task utility for executed cover	1 / 1	0/1	WRA's five research decoys report recovery and extra research; matched original-task utility is not located.

TABLE 9. TESTABLE OPEN QUESTIONS DERIVED FROM THE SYNTHESIS. Q1 SPECIFIES TRANSFER TESTS. Q2 SEPARATES THE FORWARDING MEDIATORS; Q3 EXTENDS THE CONTROLLED COVER STUDY TO APPLICATION CONSTRAINTS; Q4 EXTENDS LIVE DETECTION TO NEW WORKLOADS AND DEPLOYMENTS. EACH GIVES A RESULT THAT COULD SUPPORT OR REVISE THE PROPOSED EXPLANATION.

Question and unresolved mechanism	Controlled comparison	Discriminating result
Q1. Which signals survive execution changes? Do attacks identify recurring task structure or features tied to its implementation?	Keep task labels and observation rights fixed. Hold out compositions, coordination and client/scaffold versions separately, then jointly. Compare destination, volume/timing, sequence and recipient-visible feature families under declared frozen and adapted training.	Identify a feature family whose inference survives specified changes, or a failure tied to one changed condition. Report per-axis and joint transfer with attempted-run coverage; a pooled average cannot establish invariance.
Q2. How does feedback reach model traffic? Which part is content, length or later action structure?	Fix initial instructions and task-required fields. Pair length-matched neutral padding with validity-preserving replacement of supplementary content; hold encoding and follow-up policy fixed where possible. Vary record count separately. Compare prefix, first-feedback and complete model views under tool-only and joint protection.	Additional held-out inference after feedback, with controls that exclude the competing path, supports that attribution. Report an effect interval against a prespecified meaningful-effect threshold. A nonsignificant difference alone does not rule out leakage.
Q3. Can cover preserve task semantics? When should it stop at transport or execute in isolation?	Extend the six-condition LLM case to production tool contracts and legitimate concurrent updates. Compare no cover, transport termination and isolated execution under declared resource budgets. Refit permitted attackers; measure bytes, delay, original-task completion, quota use, state changes and feedback entering the planner.	A privacy–utility operating point satisfying prespecified state and task tolerances supports the design. Resource exhaustion, changed business state or impaired completion identifies the constraint it violates.
Q4. Which inference survives task discovery? Does cross-link association recover information hidden by waits and multiplexing?	Train on one concurrency/load and test new compositions, loads and gateways. Compare tool-only and associated tool/model views with observable flow identifiers; keep ground-truth task and stream mappings outside attacker inputs. Include real unrelated traffic and constant-output detector references.	Measure interval recall, false alarms per unit time and correctly localized inference together. Gains must survive changed workloads and loads at a stated false-alarm budget.

predicate in 102/120 Qwen runs but violate the state contract in 95 of them. Supplement S8 derives the fixture contract and fills every step.

8.2. Reusable forms

Supplement S5 provides the eight-field checklist, its correspondence to established guidance, and completed WRA, OHTTP and ANT forms. Each form records evidence, a missing item or inapplicability. Identity-obfuscation (3), adversarial-Agent blocking (2) and non-protection (35) settings keep separate denominators. The access map assigns 22 transit, 10 recipient, 11 active and one downstream preference setting.

9. Synthesis and Research Agenda

9.1. Which conclusions depend on which sources

Source withdrawal follows 33 statements across seven comparisons and 20 removal scenarios (Supplement S2.4). With only published texts, WRA and CHeaT retain query

recovery from tool destinations, the decoy/visibility utility mismatch behind Finding 2, and a defined prevention outcome. Finding 1's model-view half, live OHTTP refitting and each transfer axis depend on preprints. Our controlled measurements test the two boundaries directly but do not replace missing source coverage.

9.2. Lessons for defense designers and evaluators

1) **Name every retained view.** A tool-side or single-step defense leaves model-link, recipient and later-request views unless it is shown to cover them. Report an adapted attack on each permitted view, including single-link rules available to a joint observer.
2) **Report privacy and utility from the same intervention.** No mapped Agent privacy setting does this yet. Utility must include whole-state correctness and resources, not only task completion.
3) **Prefer the shallowest cover boundary the observer allows.** Under padded metadata, the cover schedule, not execution depth, determined residual recognition. Executed or isolated cover is justified only by an observer that a proxy cannot fool, such as one that sees timing or downstream calls.
4) **Calibrate against simple baselines.** Concurrency, position rules and constant-output detectors can rival learned attacks and costly shaping.

9.3. Tests that would change a protection decision

Table 9 turns the synthesis into four discriminating tests: transfer across execution changes, separation of forwarding effects, cover under business constraints, and inference after event discovery. For the ticket application, progress means meeting both boundaries at once: limit the observations that carry task information, and keep decoys within specified state and resource budgets.

10. Validity, Ethics and Availability

Evidence scope. Index failures and missed query terms limit coverage. Extraction is author-performed with AI assistance and has no independent human reliability estimate. Section 2 states which fields the findings depend on.

The executed-cover case uses synthetic actions, local services and reused phrasings. Its intervals condition on fitted attacks and fixtures, and its adverse writes do not estimate production prevalence or WRA's harms. Finding 3 therefore applies to a padded-metadata observer with supplied windows, an early-only decoy schedule and two 8B planners. A timing-capable observer could reward realistic execution, and a full-coverage schedule could change which attack is strongest. Business-state invariants, stronger attacks and other observation views require their own evidence.

The forwarding pilot uses category-bearing records and twenty nonempty test clusters. Projection changes content, length and execution order together, and its lessons are descriptive. The hosted retest (Supplement S1) changes backend and network together and uses an unpinned alias. It supports no main-text claim.

Ethics and assistance. All inputs are synthetic, business actions update isolated fixtures, and capture filters restrict collection to the experiment. No human participants, customer operations or provider vulnerabilities are involved. The hosted retest used the account holder's authorization; provider-specific research terms remain unverified. AI tools assisted extraction, implementation and writing; saved observations and executable analyses support every measurement. Traffic inference can enable profiling as well as monitoring. We therefore release payload-free metadata, features, predictions and offline analyses, and exclude credentials, transcripts, raw captures and third-party full texts.

Availability. The review package links the 44-setting matrix, transfer relations, eligibility ledger and source locators to each claim. It also includes synthetic planner records and fixtures for state replay, predictions, uncertainty scripts and manifests. Raw-to-metadata reconstruction needs the excluded captures.

11. Conclusion

Agent communication defenses cannot inherit WF evaluation unchanged. Tool feedback carries a task across independently controlled links, and Agent cover can execute as application work. No mapped Agent privacy setting yet reports an adapted attacker together with matched task utility. When we measured both, cover semantics barely moved recognition but determined state integrity. The procedure, checklist and agenda let future defenses report a complete privacy–utility point and show which conclusions still await published evidence.

References

[1] Y. Zhang, X. Deng, Z. Gu, Y. Chen, K. Xu, Q. Li, and J. Wu, "Exposing LLM user privacy via traffic fingerprint analysis: A study of privacy risks in LLM agent interactions," *arXiv preprint arXiv:2510.07176*, 2025. [Online]. Available: https://arxiv.org/abs/2510.07176v1

[2] H. Jeong, M. Teymoorianfard, A. Kumar, A. Houmansadr, and E. Bagdasarian, "Network-level prompt and trait leakage in local research agents," in *35th USENIX Security Symposium*. USENIX Association, 2026, pp. 6485–6504. [Online]. Available: https://www.usenix.org/conference/usenixsecurity26/presentation/jeong

[3] B. Dangol, "From privacy to workflow integrity: Communication-graph metadata in autonomous agent interoperability," *arXiv preprint arXiv:2606.07150v3*, 2026. [Online]. Available: https://arxiv.org/abs/2606.07150v3

[4] S. Pouryousef, J. Lopez, S. R. Nowmi, M. M. Kamol, M. Hossain, M. Tran, and M. S. Rahman, "A large-scale benchmark and risk assessment of traffic analysis attacks on cloud LLM services," *arXiv preprint arXiv:2609.31877v2*, 2026. [Online]. Available: https://arxiv.org/abs/2609.31877v2

[5] C. Song, H. Wang, and R. Martin, "PersonaFingerprint: Measuring persona inference on modern websites with LLM-driven browsing," *arXiv preprint arXiv:2605.15962v1*, 2026. [Online]. Available: https://arxiv.org/abs/2605.15962v1

[6] D. Kang, H. Jeong, J. Sheffey, P. Datta, and A. Houmansadr, "Whose agent are you? multi-layer fingerprinting and attribution of autonomous web agents," *arXiv preprint arXiv:2606.20910v1*, 2026. [Online]. Available: https://arxiv.org/abs/2606.20910v1

[7] I. Fayolle, S. Bouhenniche, S. Pélissier, P. Laperdrix, C. Maurice, and W. Rudametkin, "On the internet, nobody knows you're an LLM bot: Unmasking web agents with multi-layer fingerprinting," *arXiv preprint arXiv:2606.30119v1*, 2026. [Online]. Available: https://arxiv.org/abs/2606.30119v1

[8] A. Shahriar, M. N. Rahman, S. Ahmed, F. Sadeque, and M. R. Parvez, "AgentTell: Behavioural side-channel leakage in browser-use agents," *arXiv preprint arXiv:2609.32915v1*, 2026. [Online]. Available: https://arxiv.org/abs/2609.32915v1

[9] F. Li, X. Gao, Z. Liu, T. Li, C. Fu, Z. Wang, and K. Xu, "ANT: A multi-granularity network traffic dataset and benchmark for agents behavior auditing," *arXiv preprint arXiv:2610.06514v1*, 2026. [Online]. Available: https://arxiv.org/abs/2610.06514v1

[10] D. Ayzenshteyn, R. Weiss, and Y. Mirsky, "Cloak, honey, trap: Proactive defenses against LLM agents," in *34th USENIX Security Symposium*. USENIX Association, 2025, pp. 8095–8114. [Online]. Available: https://www.usenix.org/conference/usenixsecurity25/presentation/ayzenshteyn

[11] L. Song, Z. Pang, W. Wang, Z. Wang, X. Wang, H. Chen, W. Song, Y. Jin, D. Meng, and R. Hou, "The early bird catches the leak: Unveiling timing side channels in LLM serving systems," *IEEE Transactions on Information Forensics and Security*, vol. 20, pp. 11 431–11 446, 2025, cited version: arXiv:2409.20002v5. [Online]. Available: https://ieeexplore.ieee.org/document/11206380/

[12] G. McDonald and J. B. Or, "Whisper leak: a side-channel attack on large language models," *arXiv preprint arXiv:2511.03675*, 2025, cited version: arXiv:2511.03675v1. [Online]. Available: https://arxiv.org/abs/2511.03675v1

[13] T. Zhang, G. Saileshwar, and D. Lie, "Time will tell: Timing side channels via output token count in large language models," *arXiv preprint arXiv:2412.15431*, 2024, cited version: arXiv:2412.15431v1. [Online]. Available: https://arxiv.org/abs/2412.15431v1

[14] G. Wu, Z. Li, Y. Zhang, Z. Zhang, J. Niu, Y. Wu, and Y. Zhang, "Cacheprune: Privacy-aware and fine-grained KV cache sharing for efficient LLM inference," *arXiv preprint arXiv:2605.23640v1*, 2026. [Online]. Available: https://arxiv.org/html/2605.23640v1

[15] M. Juarez, S. Afroz, G. Acar, C. Diaz, and R. Greenstadt, "A critical evaluation of website fingerprinting attacks," in *Proceedings of the ACM SIGSAC Conference on Computer and Communications Security*, 2014, pp. 263–274.

[16] N. Mathews, J. K. Holland, S. E. Oh, M. S. Rahman, N. Hopper, and M. Wright, "SoK: A critical evaluation of efficient website fingerprinting defenses," in *IEEE Symposium on Security and Privacy*, 2023.

[17] T. Wang and I. Goldberg, "Walkie-talkie: An efficient defense against passive website fingerprinting attacks," in *26th USENIX Security Symposium*, 2017. [Online]. Available: https://www.usenix.org/conference/usenixsecurity17/technical-sessions/presentation/wang-tao

[18] J. Gong and T. Wang, "Zero-delay lightweight defenses against website fingerprinting," in *29th USENIX Security Symposium*. USENIX Association, 2020, pp. 717–734. [Online]. Available: https://www.usenix.org/conference/usenixsecurity20/presentation/gong

[19] F. Tramèr, N. Carlini, W. Brendel, and A. Madry, "On adaptive attacks to adversarial example defenses," in *Advances in Neural Information Processing Systems*, vol. 33, 2020. [Online]. Available: https://arxiv.org/abs/2002.08347v2

[20] R. Weiss, D. Ayzenshteyn, G. Amit, and Y. Mirsky, "What was your prompt? a remote keylogging attack on ai assistants," in *33rd USENIX Security Symposium*, 2024. [Online]. Available: https://www.usenix.org/conference/usenixsecurity24/presentation/weiss

[21] N. Carlini and M. Nasr, "Remote timing attacks on efficient language model inference," *arXiv preprint arXiv:2410.17175v1*, 2024. [Online]. Available: https://arxiv.org/html/2410.17175v1

[22] D. Ahmed, A. Sabir, and A. Das, "Spying through your voice assistants: Realistic voice command fingerprinting," in *32nd USENIX Security Symposium*, 2023, pp. 2419–2436. [Online]. Available: https://www.usenix.org/conference/usenixsecurity23/presentation/ahmed-dilawer

[23] Model Context Protocol, "Transports," 2025, protocol version 2025-06-18. [Online]. Available: https://modelcontextprotocol.io/specification/2025-06-18/basic/transports

[24] M. Thomson and C. Benfield, "HTTP/2," RFC 9113, 2022. [Online]. Available: https://www.rfc-editor.org/rfc/rfc9113.html

[25] E. Rescorla, "The transport layer security (tls) protocol version 1.3," RFC 8446, 2018. [Online]. Available: https://www.rfc-editor.org/rfc/rfc8446.html

[26] W. Lugoloobi, S. Marro, J. Magomere, J. Wright, and C. Russell, "Known by their actions: Fingerprinting LLM browser agents via UI traces," *arXiv preprint arXiv:2605.14786v1*, 2026. [Online]. Available: https://arxiv.org/abs/2605.14786v1

[27] J. Roh, E. Bagdasarian, H. Haddadi, and A. S. Shamsabadi, "SPILLage: Agentic oversharing on the web," *arXiv preprint arXiv:2602.13516v1*, 2026. [Online]. Available: https://arxiv.org/abs/2602.13516v1

[28] S. Chen, R. Wang, X. Wang, and K. Zhang, "Side-channel leaks in web applications: A reality today, a challenge tomorrow," in *IEEE Symposium on Security and Privacy*, 2010. [Online]. Available: https://staff.ie.cuhk.edu.hk/~khzhang/my-papers/2010-oakland-side-channel.pdf

[29] P. Chapman and D. Evans, "Automated black-box detection of side-channel vulnerabilities in web applications," in *ACM Conference on Computer and Communications Security*, 2011. [Online]. Available: https://www.cs.virginia.edu/~evans/pubs/ccs2011/

[30] P. Reynolds, J. L. Wiener, J. C. Mogul, M. K. Aguilera, and A. Vahdat, "WAP5: Black-box performance debugging for wide-area systems," in *International World Wide Web Conference*, 2006. [Online]. Available: https://cseweb.ucsd.edu/~vahdat/papers/wap5-www06.pdf

[31] B. C. Tak, C. Tang, C. Zhang, S. Govindan, B. Urgaonkar, and R. N. Chang, "vPath: Precise discovery of request processing paths from black-box observations of thread and network activities," in *USENIX Annual Technical Conference*, 2009. [Online]. Available: https://www.usenix.org/conference/usenix-09/vpath-precise-discovery-request-processing-paths-black-box-observations-thread

[32] K. P. Dyer, S. E. Coull, T. Ristenpart, and T. Shrimpton, "Peek-a-boo, i still see you: Why efficient traffic analysis countermeasures fail," in *IEEE Symposium on Security and Privacy*, 2012. [Online]. Available: https://pages.cs.wisc.edu/~rist/papers/trafanal.pdf

[33] R. Trimananda, J. Varmarken, A. Markopoulou, and B. Demsky, "Packet-level signatures for smart home devices," in *Network and Distributed System Security Symposium*, 2020. [Online]. Available: https://www.ndss-symposium.org/ndss-paper/packet-level-signatures-for-smart-home-devices/

[34] N. Apthorpe, D. Y. Huang, D. Reisman, A. Narayanan, and N. Feamster, "Keeping the smart home private with smart(er) IoT traffic shaping," *Proceedings on Privacy Enhancing Technologies*, vol. 2019, no. 3, pp. 128–148, 2019. [Online]. Available: https://petsymposium.org/popets/2019/popets-2019-0040.pdf

[35] D. Duan, Q. Liu, Y. Liu, N. Zou, X. Hu, and D. Liu, "How much can tool calls reveal about you? privacy leakage from tool-call traces," *arXiv preprint arXiv:2610.41885v1*, 2026. [Online]. Available: https://arxiv.org/abs/2610.41885v1

[36] Y. Yao, Z. Wang, H. Cheng, Y. Cheng, H. Du, and X.-Y. Li, "IntentMiner: Intent inversion attack via tool call analysis in the model context protocol," *arXiv preprint arXiv:2512.14166v2*, 2026. [Online]. Available: https://arxiv.org/abs/2512.14166v2

[37] P. Sirinam, M. Imani, M. Juarez, and M. Wright, "Deep fingerprinting: Undermining website fingerprinting defenses with deep learning," in *Proceedings of the ACM SIGSAC Conference on Computer and Communications Security*, 2018. [Online]. Available: https://arxiv.org/abs/1801.02265v5

[38] S. Bhat, D. Lu, A. Kwon, and S. Devadas, "Var-CNN: A data-efficient website fingerprinting attack based on deep learning," *Proceedings on Privacy Enhancing Technologies*, vol. 2019, no. 4, pp. 292–310, 2019. [Online]. Available: https://petsymposium.org/popets/2019/popets-2019-0070.php

[39] M. Bishop, "HTTP/3," RFC 9114, 2022. [Online]. Available: https://www.rfc-editor.org/rfc/rfc9114.html

[40] J. Iyengar and M. Thomson, "QUIC: A UDP-based multiplexed and secure transport," RFC 9000, 2021. [Online]. Available: https://www.rfc-editor.org/rfc/rfc9000.html

[41] C. Song, D. D. M. Mekala, H. Wang, and R. P. Martin, "Redefining website fingerprinting attacks with multi-agent LLMs," *Proceedings on Privacy Enhancing Technologies*, vol. 2026, no. 3, pp. 688–702, 2026. [Online]. Available: https://www.petsymposium.org/popets/2026/popets-2026-0101.php

[42] S. Zavrak, "Content-aware attack detection in LLM agent tool-call traffic: An empirical study of features, architectures, and evaluation protocols," *arXiv preprint arXiv:2605.11053v3*, 2026. [Online]. Available: https://arxiv.org/abs/2605.11053v3

[43] Z. Guan, G. Xiong, G. Gou, Z. Li, M. Cui, and C. Liu, "BAPM: Block attention profiling model for multi-tab website fingerprinting attacks on Tor," in *Annual Computer Security Applications Conference*, 2021.

[44] X. Deng, Q. Yin, Z. Liu, X. Zhao, Q. Li, M. Xu, K. Xu, and J. Wu, "Robust multi-tab website fingerprinting attacks in the wild," in *IEEE Symposium on Security and Privacy*, 2023, pp. 1005–1022.

[45] T. Wang and I. Goldberg, "On realistically attacking Tor with website fingerprinting," *Proceedings on Privacy Enhancing Technologies*, vol. 2016, no. 4, pp. 21–36, 2016.

[46] J. Hayes and G. Danezis, "k-fingerprinting: A robust scalable website fingerprinting technique," in *25th USENIX Security Symposium*, 2016, pp. 1187–1203. [Online]. Available: https://www.usenix.org/conference/usenixsecurity16/technical-sessions/presentation/hayes

[47] G. Zhao, H. Wu, and X. Zhang, "AgentTrace: Execution-level fingerprinting of black-box LLM agents," 2026, version 1. [Online]. Available: https://arxiv.org/abs/2610.32092v1

[48] M. Ediga and S. Chattopadhyay, "Trace: Unmasking AI attack agents through terminal behavior fingerprinting," 2026, version 1. [Online]. Available: https://arxiv.org/abs/2605.01186v1

[49] O. Borysenko, "Developer experience with AI coding agents: HTTP behavioral signatures in documentation portals," 2026, extended version 3. [Online]. Available: https://arxiv.org/abs/2604.02544v3

[50] ——, "Documentation retrieval by AI coding agents: An empirical study of HTTP behavioral signatures," in *Proceedings of the 1st International Workshop on Agentic AI for Next-Generation Software Development*. ACM, 2026, pp. 168–169.

[51] Reworr and D. Volkov, "LLM agent honeypot: Monitoring AI hacking agents in the wild," 2025, version 2; first submitted 2024. [Online]. Available: https://arxiv.org/abs/2410.13919v2

[52] D. Arp, E. Quiring, F. Pendlebury, A. Warnecke, F. Pierazzi, C. Wressnegger, L. Cavallaro, and K. Rieck, "Dos and don'ts of machine learning in computer security," in *31st USENIX Security Symposium (USENIX Security 22)*. USENIX Association, 2022, pp. 3971–3988. [Online]. Available: https://www.usenix.org/conference/usenixsecurity22/presentation/arp

[53] Y. Yao, J. Duan, K. Xu, Y. Cai, Z. Sun, and Y. Zhang, "A survey on large language model (LLM) security and privacy: The good, the bad, and the ugly," *arXiv preprint arXiv:2312.02003v3*, 2024. [Online]. Available: https://arxiv.org/abs/2312.02003v3

[54] A. Shahriar, M. N. Rahman, S. Ahmed, F. Sadeque, and M. R. Parvez, "A survey on agentic security: Applications, threats and defenses," *arXiv preprint arXiv:2510.06445v1*, 2025. [Online]. Available: https://arxiv.org/abs/2510.06445v1

[55] M. A. Ferrag, N. Tihanyi, D. Hamouda, L. Maglaras, and M. Debbah, "From prompt injections to protocol exploits: Threats in LLM-powered AI agents workflows," *arXiv preprint arXiv:2506.23260v1*, 2025. [Online]. Available: https://arxiv.org/abs/2506.23260v1

[56] LangChain, "LangGraph, version 1.0.3," Software release, November 10, 2025. [Online]. Available: https://pypi.org/project/langgraph/1.0.3/

[57] E. Debenedetti, I. Shumailov, T. Fan, J. Hayes, N. Carlini, D. Fabian, C. Kern, C. Shi, A. Terzis, and F. Tramèr, "Defeating prompt injections by design," 2025, version 2. [Online]. Available: https://arxiv.org/abs/2503.18813v2

[58] M. Costa, B. Köpf, A. Kolluri, A. Paverd, M. Russinovich, A. Salem, S. Tople, L. Wutschitz, and S. Zanella-Béguelin, "Securing AI agents with information-flow control," 2025, version 2. [Online]. Available: https://arxiv.org/abs/2505.23643v2

[59] T. Shi, J. He, Z. Wang, H. Li, L. Wu, W. Guo, and D. Song, "Progent: Programmable privilege control for LLM agents," 2025, version 2. [Online]. Available: https://arxiv.org/abs/2504.11703v2

[60] S. Yao, N. Shinn, P. Razavi, and K. Narasimhan, "τ-bench: A benchmark for tool-agent-user interaction in real-world domains," 2024, version 1. [Online]. Available: https://arxiv.org/abs/2406.12045v1

[61] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr, "AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents," in *Advances in Neural Information Processing Systems*, vol. 37, 2024. [Online]. Available: https://proceedings.neurips.cc/paper_files/paper/2024/hash/97091a5177d8dc64b1da8bf3e1f6fb54-Abstract-Datasets_and_Benchmarks_Track.html

[62] X. Cai, R. Nithyanand, T. Wang, R. Johnson, and I. Goldberg, "A systematic approach to developing and evaluating website fingerprinting defenses," in *Proceedings of the ACM SIGSAC Conference on Computer and Communications Security*, 2014, pp. 227–238.